COURSE: WEB SECURITY & PENETRATION TESTING

LAB ASSIGNMENT REPORT: DAY 35 LOGGING & ALERTING

Student Name: Jiwosh Shrestha

Topic: Logging, Monitoring & Alerting Fundamentals

Assignment: Day 35 - Logging & Alerting

Focus: OWASP A09 - Security Logging & Alerting

PART 1: LOGGING, MONITORING & ALERTING FUNDAMENTALS

Question 1: Explain the difference between Logging, Monitoring and Alerting.

• Logging is the act of recording discrete events (who did what, when, from where, and the outcome) into persistent records.
• Monitoring is the continuous observation, parsing, and analysis of those log records and system metrics to establish baselines and detect abnormal behavior.
• Alerting is the automated generation of notifications when monitoring rules detect conditions that cross specific thresholds or match threat signatures, allowing human or automated systems to respond.

Question 2: List at least six security-relevant application events that should be considered for logging. Explain why any two are important.

Six Security Events:
1. Successful and failed authentication attempts
2. Password-reset or account-lockout actions
3. Privilege-escalation or role-change events
4. Access to sensitive data or administrative functions
5. Changes to security configurations or firewall rules
6. Creation, modification, or deletion of user accounts

Importance of Key Events:
• Authentication Failures: Critical because repeated failures indicate brute-force, password-guessing, or credential-stuffing attacks.
• Privilege-Escalation Events: Crucial because they indicate an attacker who has compromised a low-privilege account and is attempting to gain administrative control.

Question 3: List at least five examples of sensitive information that should normally not appear in application logs.

1. Plain-text passwords or password hashes
2. Session tokens, JWT/bearer tokens, or API keys
3. Full credit card numbers, CVVs, or financial records
4. Personally Identifiable Information (PII) such as national ID numbers or home addresses
5. Encryption private keys, certificates, or MFA secrets

Question 4: Why should security logs be protected from unauthorized modification or deletion? Give two controls.

Security logs represent the definitive forensic evidence of system activity. If an attacker alters or deletes log entries during or after a breach, the incident becomes invisible, preventing accurate incident response and forensic investigation.

Two Protective Controls:
1. Remote Append-Only SIEM/Log Server: Stream logs in real time to a centralized, remote log repository that application servers cannot modify or erase.
2. Cryptographic Integrity & Least Privilege: Apply cryptographic hash-chaining or digital signatures to log streams, and restrict write access to low-privilege logging service accounts.

Question 5: Design one simple alert rule for detecting suspicious repeated authentication failures. Include Condition, Time Window, Severity and Recommended Action.

• Condition: > 10 failed login attempts from the same source IP (or against the same user account)
• Time Window: 5 minutes
• Severity: High
• Recommended Action: Temporarily block the source IP at the perimeter, generate a high-priority SOC ticket, and alert the security team.

Question 6: Explain False Positive and Alert Fatigue. Why can excessive alerts reduce security effectiveness?

• False Positive: An alert triggered by normal or benign activity that does not represent a true security incident.
• Alert Fatigue: A state of desensitization experienced by security analysts when inundated with a high volume of low-value or false alerts.

Impact: Excessive alerts cause analysts to ignore notifications or delay response times, leading to missed critical security incidents and diminished trust in the monitoring system.

PART 2: PRACTICAL LAB & AUTHENTICATION FAILURE ANALYSIS

Question 7: Using the supplied Day 35 training log: identify the suspicious source, failure count, time window, and provide a short investigation summary.

Investigation Findings (Day 35 Training Log):
• Suspicious Source IP: 203.0.113.47
• Failure Count: 18 failed authentication attempts
• Time Window: 14:02:11 to 14:06:48 UTC (~4 minutes 37 seconds)

auth.log Day 35 Training Sample Excerpt:

```
2026-10-14 14:02:11 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:02:28 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:03:05 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:03:41 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:04:12 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:05:03 FAILED user=admin src=203.0.113.47 reason=invalid_password
2026-10-14 14:06:48 FAILED user=admin src=203.0.113.47 reason=invalid_password
```

Short Investigation Summary:
IP 203.0.113.47 generated 18 consecutive failed login attempts targeting privileged accounts (admin/root) within a 5-minute window. The rapid sequence and uniform failure reasons indicate an automated password-guessing or credential-stuffing attempt. Recommended action: block source IP, force password reset on targeted accounts, and trigger a High-severity alert.

PART 3: SECURE LOGGING & ALERTING DESIGN RECOMMENDATIONS

Question 8: Provide at least five recommendations for a secure application logging and alerting system.

1. Comprehensive Event Scope: Log all security-relevant events (authentication, authorization changes, privilege escalations) with adequate context (user, source IP, timestamp, outcome).
2. Data Sanitization: Strictly prohibit logging sensitive data such as passwords, tokens, API keys, or unmasked PII.
3. Centralized Real-Time Forwarding: Ship logs in real time to a centralized, append-only SIEM or log repository inaccessible to the source application host.
4. Cryptographic Integrity Protection: Enforce log immutability via hash chaining, digital signatures, and strict role-based access controls.
5. High-Signal Alert Tuning: Design precise alert rules with clear thresholds, severity levels, and automated playbooks to eliminate false positives and prevent alert fatigue.